

Cybersecurity Plan for XYZ Insurance

Matthew Gurule

June 7, 2026

Table of Contents

Cybersecurity Plan for XYZ Insurance	3
Cybersecurity at XYZ: Roles, Key Elements, and Strategic Value	4
Role of Cybersecurity at XYZ.....	4
Cybersecurity Elements and Benefits.....	5
Impact of Compliance and Governance at XYZ.....	6
Impact of Compliance and Governance.....	6
Compliance Applicable to XYZ	7
Incorporating Compliance in Cybersecurity Strategy	8
XYZ's NIST Implementation Strategy	9
Application of Core Functions	9
Implementation Goals.....	11
XYZ Profile Creation.....	11
Planning for Risk Management at XYZ.....	12
Steps in Determining Risk	12
Risk Concerns.....	13
Risk Assessment: Qualitative vs Quantitative	14
Assessment Model for Cybersecurity Projects	15
Return on Investment (ROI) vs Return on Security Investment (ROSI)	15
Risk Matrix	16
Planning for Incident Management	18
Before an Incident	18
During an Incident	18
After an Incident	19
Post-Incident Lessons Learned	20
Conclusion	20
References	22

Cybersecurity Plan for XYZ Insurance

With the threat landscape and technology continuing to evolve, cybersecurity has become a necessary function for businesses that store, process, and transmit sensitive data. As the new Chief Information Officer (CIO) of XYZ, the primary objective is to develop a comprehensive cybersecurity plan to protect systems, data, and operations at both of its locations. XYZ's two locations include a corporate office in Chicago and a satellite office in Denver. The Chicago office hosts 800 servers running a mix of modern and legacy software from Windows XP, Windows 7, all the way up to Windows 11. This office also hosts 600 desktop users and 400 laptop users for a total of 1,000 users, running Windows 10 with 8GB of RAM. Additionally, the Chicago location has IT staff consisting of four techs and one tech lead, with a fully staffed Network Operations Center (NOC). Meanwhile, the Denver location houses 400 servers running a mix of operating systems, as in Chicago. Denver's staff includes 250 desktop users and 150 laptop users, also running Windows 10 with 8GB of RAM, along with three techs, one lead tech, and a fully staffed NOC. Considering the two distinct locations, legacy systems, large user base, and sensitive insurance data, several cybersecurity challenges arise that must be addressed through a comprehensive cybersecurity plan.

To protect assets, manage risk effectively, ensure business success, meet goals, and maintain operations at both locations for its 1,400 users, XYZ Insurance needs a comprehensive cybersecurity plan aligned with a proven framework, specifically the National Institute of Standards and Technology (NIST) Cybersecurity Framework 2.0. This document examines the role of cybersecurity, the impact of compliance and governance, the practical implementation of the NIST CSF core functions, risk management practices, cybersecurity assessment methods, and incident management procedures. Together, these cybersecurity components establish a formal,

organized approach to protect XYZ assets, reduce cybersecurity risk, support regulatory compliance, and reinforce the overall security posture across the business.

Cybersecurity at XYZ: Roles, Key Elements, and Strategic Value

Role of Cybersecurity at XYZ

Considering every business can be a target for threat actors, cybersecurity must be a top priority at XYZ. Insurance companies are major targets for cyberattacks due to the large amounts of sensitive data they store, their increasing use of technology, which increases exposure, and the sheer scale of the industry (Chin, 2025). Consequently, XYZ is a prime target across its environment where users rely on secure systems to process, store, and transmit data. A single cybersecurity incident could result in a breach of sensitive information, disrupted operations, and serious legal, financial, and reputational damage. These real-world consequences demonstrate why cybersecurity must be a focus at XYZ, as evidenced by the Equifax breach.

The Equifax breach shows how one cyber incident can lead to serious financial, reputational, and legal consequences. Data of approximately 147 million individuals, including Social Security numbers and financial information, was exposed. This led to a \$700 million settlement, significant reputational damage, loss of consumer trust, and regulatory scrutiny (Danielson, 2025). This demonstrates the financial, operational, legal, and reputational damages XYZ could face if it is not proactive in its cybersecurity measures. Furthermore, insurance-specific regulations, such as the New York Department of Financial Services (NYDFS) Cybersecurity Regulation, establish baseline measures, including formal cybersecurity programs, written security policies, governance and reporting responsibilities, and Incident Response Plans (IRPs) (Cihangir, 2025). This is important because regulations like these establish a legal floor for cybersecurity that XYZ must adhere to regardless of its risk appetite or business goals.

Preventing breaches like the Equifax incident at XYZ requires a focus on the confidentiality, integrity, and availability of all systems and data for every user and server at both locations.

Cybersecurity Elements and Benefits

Implementing cybersecurity at XYZ Insurance will be guided by the core principles of confidentiality, integrity, and availability, also known as the CIA Triad. Confidentiality ensures that sensitive data, such as customers' financial, policy, and Personally Identifiable Information (PII), remains protected from unauthorized access. This is vital to maintaining customer trust and complying with regulations. The integrity element safeguards data accuracy, preventing unauthorized alteration, which is extremely important for insurance claims handling and policy management. Finally, availability ensures that legitimate users, including customers and employees, can access the data and systems they need when they need. In conjunction with other elements, the CIA Triad supports data protection, business continuity, and XYZ's operations and goals across its users and systems at both locations.

Identity and Access Management (IAM) is another important cybersecurity element for XYZ, as it helps control who can access systems and data at its two locations and 1,400 users. Part of the IAM component will be to implement Multifactor Authentication (MFA), requiring employees to provide more than just their username and password. For example, after entering the correct credentials, MFA may require a one-time SMS code to complete the login process. As a result, even if a user's credentials are compromised, the likelihood of unauthorized access to XYZ systems is drastically reduced. Additionally, XYZ will apply the Principles of Least Privilege (PoLP) with MFA to reduce the impact if unauthorized access still occurs. The PoLP ensures employees have only the access they need to perform their jobs, limiting the reach a threat actor has if they gain access to a user account. Ultimately, IAM decreases disruptions,

unauthorized access, and the impact of compromised accounts, reinforcing the CIA of XYZ systems and data.

Vulnerability and patch management, along with network segmentation, are vital cybersecurity components for mitigating risk at XYZ, especially for the legacy systems. For example, Windows 7 was shown to have over 43 Common Vulnerabilities and Exposures (CVEs) in 2023, making it a top target for threat actors (LaPorte, 2025). Since legacy systems, like XYZ's Windows 7 computers, receive little to no patches, XYZ must take more aggressive measures, including network segmentation to isolate them and prevent attackers from moving laterally during a breach. These efforts are complicated by XYZ's physical infrastructure, which includes 800 servers in Chicago and 400 in Denver. Consequently, segmentation must account for both geographic locations and the mix of legacy and modern systems. This prevents attackers from moving between network segments and accessing other systems. Additionally, any vulnerabilities that can be mitigated and any available patches should be applied. Modern systems can also have vulnerabilities, making regular patch management vital. While not exhaustive, these elements address some of the more serious risks and demonstrate how tailored improvements can enhance XYZ's overall security posture. However, implementing and maintaining these controls effectively requires strong governance and compliance practices to ensure they are applied consistently across the business.

Impact of Compliance and Governance at XYZ

Impact of Compliance and Governance

Compliance and governance shape how cybersecurity is adopted at XYZ through NIST CSF 2.0. A core element of the NIST framework is the Govern function, which creates and oversees cybersecurity strategy, policies, and risk management approaches. This aligns

cybersecurity efforts with business goals and stakeholder expectations. The framework also guides other functions by incorporating cybersecurity into enterprise risk management (NIST, 2024). This ensures XYZ maintains robust cybersecurity policies. As a result, compliance is supported through those policies, helping XYZ meet regulatory requirements while reducing risk through organized, consistent security practices. The Govern function ensures policies apply across both locations and all systems, including vulnerable legacy systems. It also helps XYZ develop risk-based policies to manage those systems using compensatory controls, network segmentation, and documenting the risk acceptance when removing it is not yet feasible. Without strong governance, policies may not be applied consistently, increasing risk for the whole business. Ultimately, the NIST framework shapes how cybersecurity is implemented and maintained at XYZ Insurance, helping ensure the cybersecurity program aligns with laws, regulations, and standards applicable to the insurance industry.

Compliance Applicable to XYZ

XYZ must adhere to multiple regulatory frameworks applicable to insurance companies. In the US, insurance companies must adhere to the NAIC Insurance Data Security Model, NYDFS Cybersecurity Regulations, and Health Insurance Portability and Accountability Act (Cihangir, 2025). Other laws and standards include the Gramm-Leach-Bliley Act and the Payment Card Industry Data Security Standard (Anchore, 2025). These are only some requirements, as XYZ must also account for state-specific laws.

State-level compliance requirements are equally important at XYZ. Colorado laws include the Colorado Privacy Act, the Colorado Consumer Protection Act, the Colorado Data Breach Notification Law, and the Colorado Cybercrime Statute, among others (Baker Law Group, PLLC, n.d.). Illinois has the Illinois Personal Information Protection Act and the Illinois

Electronic Commerce Security Act (Wolverton, n.d.). Simply put, not only does XYZ have to account for broader compliance laws, regulations, and standards, but also state-level ones. In practice, this means XYZ will standardize policies, align controls to regulations, and enforce them across systems and locations in line with NIST CSF 2.0. Consequently, this reinforces the impact of compliance and governance across both locations.

Incorporating Compliance in Cybersecurity Strategy

Incorporating compliance and meeting requirements, such as those above, requires XYZ's cybersecurity strategy to align with those laws, regulations, and standards, as well as with NIST CSF 2.0. As discussed, the Govern function in the framework establishes security policies, risk management, oversight, and guides all other functions, thereby aiding regulatory compliance. For XYZ, adopting the CSF means compliance requirements are incorporated directly into their cybersecurity plan from the start. As the CSF focuses on outcomes, the result is effective governance and risk management that translates to compliance. Adhering to the framework ensures that XYZ implements security measures, such as MFA, access controls, and incident response. This helps meet security and regulatory obligations, such as those under the NAIC Insurance Data Security Model and Health Insurance Portability and Accountability Act (HIPAA). In addition, this supports reporting requirements outlined in the NYDFS Cybersecurity Regulations, ensuring that qualifying cybersecurity incidents are identified, documented, and reported within the required timeframes. While the NIST CSF provides the foundation for implementing compliance within XYZ's cybersecurity strategy, it is also flexible enough to work with other tools.

The NIST CSF naturally supports compliance outcomes, but supplemental processes from other sources help establish a structured process to implement and maintain compliance at

XYZ. Anchore (2025) provides a broad guide that includes identifying applicable laws and regulations, conducting a gap analysis, prioritizing risks, developing a roadmap for implementing compliance, and continuous monitoring and improvement. This helps XYZ ensure compliance is a continuous, location-tailored process. For example, the gap analysis will prioritize the corporate Chicago office first because it houses the majority of XYZ's servers and users, followed by the Denver satellite office, which houses the smaller portion of servers and users. XYZ will implement strong access controls and MFA across both locations to reduce the risk of unauthorized access. This meets multiple regulatory obligations, including those mentioned above. Combined with the NIST CSF and its core functions, these processes support the practical implementation of cybersecurity controls at XYZ.

XYZ's NIST Implementation Strategy

Application of Core Functions

NIST CSF 2.0 has six core functions that XYZ will apply to create a robust cybersecurity plan, the first two being Govern and Identify. Govern lays the foundation for the rest of the functions by focusing on establishing, communicating, and overseeing the broader cybersecurity strategy, policies, and risk management. The Identify function helps organizations understand their current cybersecurity risks by identifying vital assets, systems, people, and suppliers, along with the threats they pose. This function aligns security efforts with business goals and identifies areas for improvement, such as policies and procedures (NIST, 2024). In practice, this means that XYZ will use these functions to create cybersecurity policies, identify sensitive customer information, and assess risks posed by legacy systems at both locations.

The Protect and Detect functions help decrease cybersecurity incidents and improve threat identification. The Protect function emphasizes safeguards that reduce the likelihood and

impact of cybersecurity incidents. The Detect function helps identify and analyze potential threats or unusual activity, enabling faster responses and recovery (NIST, 2024). At XYZ, the Protect function will include security controls, such as multifactor authentication (MFA) and encryption. Furthermore, XYZ will use Security Education, Training, and Awareness (SETA) and strong IAM. Since the Chicago office supports 1,000 users and the most servers, training there will emphasize role-based awareness, phishing simulations, and coordination through IT leaders and the NOC. The Denver office, which supports 400 users and 400 servers, will receive similar core training and more targeted training from local leaders to address the specific needs of the satellite location. Network segmentation and routine patch management will reduce risks associated with legacy systems. Continuous monitoring through an Intrusion Detection and Prevention System (IDPS) supports the Detect component. These systems help identify suspicious activity before systems or data are compromised.

Lastly, the Respond and Recover functions support incident management and business continuity after an attack. The Respond function emphasizes managing, analyzing, mitigating, and communicating cybersecurity incidents to contain their impact. The Recover function helps restore affected systems, services, and operations after an incident while supporting communication during recovery activities (NIST, 2024). These two functions are vital to XYZ in the event of an attack that threatens sensitive customer or insurance claim data. Under Respond, XYZ will implement a thorough IRP, ensuring employees understand their roles and responsibilities during an incident, improve communication, and enable quick threat containment. For example, if a phishing attack targets any of the 1,400 users, the Incident Response Team (IRT) can swiftly notify the affected employees, disable compromised accounts, require credential resets, and provide guidance to prevent future compromise. Afterward, the

disaster recovery plan and system backups established in the Recovery function will help XYZ restore operations more quickly, minimizing downtime and financial damage. Frequent backup testing and incident response drills will improve recovery readiness and response times, helping XYZ achieve its implementation goals.

Implementation Goals

By implementing the NIST framework, XYZ Insurance aims to strengthen its security posture and reduce cybersecurity risks. One major goal is to protect sensitive data through 100% data classification, encryption, and access controls across both locations within six months. Additionally, XYZ will aim to reduce risks linked to legacy systems through network segmentation and routine patch management. The goal is to have 95% or more critical patches applied to systems and servers within 30 days of release. Another goal is efficient, effective incident detection and response to mitigate damage, with a target of detecting in four hours or less. XYZ also aims to ensure continued business operations and fast recovery from incidents. Measuring progress towards these goals means XYZ will establish cybersecurity profiles that outline its current security posture and desired state.

XYZ Profile Creation

Developing a cybersecurity profile for XYZ involves a structured approach supported by the NIST framework. The Current Profile states the current cybersecurity outcomes an organization is achieving and the extent to which they are being achieved. Meanwhile, the Target Profile identifies the desired and prioritized outcomes needed to meet cybersecurity risk management goals, while accounting for potential changes, such as new requirements, technologies, and evolving threats. The first step in NIST CSF 2.0 for creating a profile is defining the scope. The next step is gathering information on cybersecurity and risk management

for the profile. Then, the organization should document the Current and Target Profiles, analyze the gaps between them, create an action plan, and update the profiles as improvements are made (NIST, 2024).

To get from the Current Profile to the Target Profile, XYZ will prioritize identified gaps based on risk appetite, regulatory obligations, resource availability, and potential operational impact. Gap analysis participants should include IT, legal, leadership, and other relevant stakeholders to ensure cybersecurity improvements align with regulations, business goals, and insurance-specific risks. This helps manage the workload with limited IT staff and leverages existing asset inventories, NOC monitoring data, and input from lead techs at both locations to develop and maintain the profiles. This process will help XYZ identify risks associated with legacy systems, limited IT staff, and sensitive data shared between locations. In addition, comparing XYZ's current standing to the targeted standing will allow the business to apply targeted improvements, such as stronger access controls. By following the NIST CSF profile creation process, XYZ can continuously improve its security posture and align security efforts with NIST outcomes, providing a foundation for effective risk management.

Planning for Risk Management at XYZ

Steps in Determining Risk

The first two steps in risk management are to identify and analyze risks. The first step organizations must take is to identify internal and external risks, such as legal, operational, and cybersecurity threats. Identifying threats early helps ensure risks are communicated throughout the organization. Once identified, organizations need to analyze the likelihood, impact, affected business areas, and root causes of risks. Organizations must also identify existing risk controls (Thomas, n.d.). In practice, this means XYZ will start by identifying risks, such as insider

threats, ransomware, unauthorized access, and phishing attacks. XYZ would then analyze the likelihood and potential impact of each risk to prioritize mitigation.

The next two steps in risk management are to evaluate and treat risks. Organizations prioritize risks based on likelihood and impact, with the highest-risk threats receiving the most attention. Then, the business can implement corrective measures to mitigate, transfer, or accept risks (Thomas, n.d.). This allows XYZ to evaluate risks associated with legacy systems, which are more vulnerable because they receive few to no security updates. From there, XYZ can implement controls, such as network segmentation and MFA, to address the risk.

However, risk management requires continual monitoring even after risks are treated. In the final step of risk management, risks are monitored and reviewed to ensure their potential severity stays in an acceptable range and any changes are quickly addressed. Not all risks can be eliminated, making continuous monitoring through employees and automated systems essential (Thomas, n.d.). XYZ must adopt continuous monitoring to ensure new and existing threats are managed and addressed effectively across both locations, using tools such as Security Information and Event Management (SIEM) systems and IDPS. These five steps help XYZ reinforce its security posture and reduce cybersecurity risk, especially those risks most concerning to the organization.

Risk Concerns

The risk management plan at XYZ aims to address a variety of risks, including one already mentioned: vulnerable legacy systems. These systems receive few, if any, security updates. XYZ's continued use of these systems is a significant concern because they are more vulnerable to exploitation. If attackers can access these systems, they may exploit known vulnerabilities to gain unauthorized access, traverse the network, or exfiltrate sensitive data.

Attacks may also spread between locations through the network. Successful attacks on these systems may lead to operational disruptions and legal, financial, and reputational damage, such as those seen in the Equifax incident.

Another major concern at XYZ involves insider threats, regardless of intent. For example, insider threats are those stemming from individuals with authorized access, such as an employee, vendor, or partner, who intentionally abuse that access for malicious purposes, such as ransomware. In 2020, insider threats cost businesses an average of \$11.45 million (Fortinet, n.d.). With 1,400 users, XYZ faces an increased risk of insider threats from disgruntled employees. Employees can also unintentionally become insider threats by falling for phishing attacks, failing to follow policies, or engaging in negligence. As a result, employee actions may lead to data exfiltration, unauthorized access, operational disruptions, and financial, legal, or reputational damage. While not an exhaustive list, legacy systems and human-related threats are among the top risks facing XYZ and must be evaluated to determine their likelihood and impact.

Risk Assessment: Qualitative vs Quantitative

When conducting risk assessments, organizations often use both qualitative and quantitative methods to evaluate cybersecurity risks. Qualitative risk assessment relies on professional judgment, and quantitative risk assessment uses verifiable, specific data (SafetyCulture, 2026). Both approaches benefit XYZ's risk assessment efforts. For example, XYZ will gather quantitative data from publicly available reports on past breaches involving insurance companies. This will help estimate the likelihood and potential financial impact of incidents at XYZ, such as ransomware attacks. In qualitative assessments, leadership and IT staff can use experience and judgment to classify risks based on likelihood and impact. For example, IT leads may determine that limited IT staff could delay incident response and increase recovery

time after a ransomware attack. Once risks have been assessed, XYZ can make more informed decisions about cybersecurity investments and prioritize controls that deliver the greatest benefit and risk reduction.

Assessment Model for Cybersecurity Projects

Return on Investment (ROI) vs Return on Security Investment (ROSI)

ROI measures the return on a traditional business investment by comparing the investment's monetary gain to its cost. ROI is the classic financial metric for measuring the profitability of an investment. ROI is found by comparing the gain, which is the increased revenue, profits, or reduced costs from the investment to the cost of the investment (Carpenter, 2025). To calculate ROI, net income is divided by the investment cost and multiplied by 100 (Filipek, 2023). For example, XYZ can use ROI to determine if spending \$50,000 (cost) on new servers to host its insurance website is profitable. Theoretically, if the investment generates \$75,000 in increased sales, the result would be a net gain of \$25,000 (net income). Thus, the formula would be $25,000 \div 50,000 \times 100$, resulting in an ROI of 50%. This is a high-level view of how typical ROI measures can help assess the value of an investment, while ROSI is tailored to security investments.

ROSI, on the other hand, assesses the value of a security investment by calculating the decrease in financial impacts of cyber risks. ROSI is a risk-based metric to calculate how much a security investment has reduced financial risk (Carpenter, 2025). Calculating ROSI requires knowing the Annual Loss Expectancy (ALE), Annualized Rate of Occurrence (ARO), Single Loss Expectancy (SLE), and mitigation ratio. ALE is the expected annual loss and is computed by multiplying the ARO by the SLE, where ARO estimates the frequency of incidents per year, and the SLE is the cost of a single incident. The mitigation ratio is the percentage of risk

decreased by a security control. Thus, the formula for ROSI is $((ALE \times \text{mitigation ratio}) - \text{cost of the solution}) \div \text{cost of the solution}$ (Filipek, 2023). For example, ROSI can be used to determine the return on a \$50,000 (cost) cybersecurity control, like an IDPS. If XYZ hypothetically uses industry reports indicating the SLE of an incident, such as ransomware, is \$100,000 and occurs once a year ($ARO = 1$), the result would be an ALE of \$100,000. If the IDPS reduces that risk by 75% (mitigation ratio), then the ALE decreases by \$75,000. The ROSI formula is then $100,000 \times 0.75 - 50,000 \div 50,000$, resulting in a 50% ROSI and a net benefit of \$25,000. This demonstrates the key difference between ROI and ROSI: ROI focuses on profitability, while ROSI measures the value of reduced security risks and potential losses, which makes it especially useful for XYZ.

Although ROI will still be used at XYZ, ROSI will be useful in creating the cybersecurity plan, as it is an investment in security. Khalil (2026) states that the average cost of a data breach was \$4.44 million in 2025. This is important because cybersecurity investments are often evaluated on the reduction in potential losses from breaches rather than on direct revenue, such as that from an online sales app. For example, XYZ's implementation of security controls like multifactor authentication, IDPS, and continuous monitoring tools does not generate profits in the traditional sense. However, these security tools drastically reduce the likelihood and impact of cybersecurity incidents across both the Denver and Chicago locations. Consequently, for XYZ, where legacy systems and limited IT staff increase risk, ROSI provides a better measurement than ROI, ensuring cybersecurity investments deliver value while reducing risk.

Risk Matrix

Like ROSI, a risk matrix is an invaluable tool for risk management, helping classify, prioritize, and visualize risks. The steps in creating a risk matrix are identifying risk, defining

likelihood and impact criteria, creating the risk matrix grid, assessing and plotting risks, reviewing and validating the matrix, and finally, monitoring and updating it (MetricStream, n.d.). Accordingly, XYZ will identify risks, including vulnerable Windows 7 and Windows XP servers, phishing attacks targeting its 1,400 users, and ransomware. After identifying risks, XYZ's limited IT staff can assess risk likelihood and impact on a scale from very low to very high. Likelihood can be determined using metrics such as industry statistics, historical incidents, known vulnerabilities, threat intelligence, and current security controls. Impact can be assessed based on potential financial loss, business disruptions, regulatory consequences, and reputational damage. For example, Khalil (2026) states ransomware was found in 44% of breaches and cost an average of \$5.08 million. Thus, ransomware may fall within the high likelihood and high impact range, especially given XYZ's legacy systems and limited IT staff. Next, the grid can be created and risks plotted according to likelihood and impact levels. Then, the matrix can be evaluated by IT staff, relevant stakeholders, and leadership to ensure its accuracy and realism. For example, leadership can compare whether legacy systems pose a greater risk than phishing attacks. This process helps ensure that risks are prioritized based on business goals and available resources. Additionally, the matrix helps prioritize mitigation efforts that align with business goals and XYZ's risk appetite. Finally, the matrix will be continuously monitored and updated as risks evolve. As a result, XYZ can use the matrix to prioritize high-impact and highly likely risks and allocate financial, human, and digital resources to them more effectively. Ultimately, the risk matrix will help XYZ make more informed decisions based on risk likelihood and impact, enabling it to be proactive rather than reactive.

Planning for Incident Management

Before an Incident

Rather than being strictly reactive, organizations must prepare, developing clear response procedures, training staff, and identifying critical systems before an incident. Preparation involves creating and updating procedures, tools, and response plans to minimize disruptions. This phase includes risk assessments, response testing, and continual refinement of response processes (Kosinski & Holdsworth, n.d.). XYZ will regularly test and refine its response procedures, enabling the limited IT staff to more efficiently identify, respond to, contain, and recover from incidents. Preparation also helps identify vulnerabilities, such as legacy systems, reducing the likelihood and impact of incidents.

Another key step in the preparation phase is establishing an IRT and building relationships with stakeholders. Organizations should form a cross-functional response team that includes legal, IT, and communications personnel. They must also build relationships with stakeholders, law enforcement, regulatory bodies, and insurance providers. These relationships improve coordination and communication during an incident (Whalley et al., 2024). Thus, XYZ will establish a cross-functional IRT with IT, legal, and comms personnel from both locations. Additionally, XYZ will build stakeholder relationships to improve coordination, reporting, and incident response responsibilities. This will help IT staff coordinate and respond to incidents more effectively.

During an Incident

During an incident, organizations must quickly identify the threat and assess the impact. Organizations must accurately detect and evaluate incidents to determine their type, scope, and severity. They must also implement monitoring tools and procedures to detect and analyze

suspicious activity (CISA, 2021). As a result, XYZ will implement continuous monitoring tools, like IDPSs, and clearly define detection procedures. XYZ will also establish activity baselines to quickly identify potential incidents. Before activating the IRP, the IRT will validate potential events by reviewing logs, alerts, and any evidence to determine whether the activity in question is truly a cybersecurity incident. This will help IT staff identify incidents faster, reduce business disruptions, and enable the cross-functional IRT to respond more effectively.

Once an incident has been confirmed, the business can move to containing it, communicating, and investigating to minimize damage and downtime. Containment focuses on preventing further damage while maintaining business operations. Organizations should isolate affected systems, preserve evidence, block unauthorized access, update security controls, and coordinate containment efforts. Threats should then be eradicated through patching, credential resets, system rebuilding, and monitoring for reinfection (CISA, 2021). In execution, XYZ will quickly isolate affected systems at both locations to prevent the incident from spreading. IT staff will preserve evidence, update security controls, reset compromised credentials, and reimage infected systems. This will reduce downtime and the likelihood of reinfection.

After an Incident

Finally, after removing the threat entirely, the recovery phase can begin. This phase concentrates on restoring systems, strengthening security controls, testing systems, and monitoring for persistent threats. Organizations should also finalize documentation, improve detection and logging, address security gaps, and apply lessons learned to future response procedures (CISA, 2021). XYZ must carefully restore and test affected systems to ensure the threat is fully eradicated. IT and the IRT staff must reinforce security controls, improve logging

and detection, and document lessons learned to improve incident response and minimize downtime.

Post-Incident Lessons Learned

While post-incident lessons learned are part of the recovery phase, they are especially important for continuous improvement. Organizations should conduct lessons learned analysis after an incident to understand what did and did not work during the response. This process includes identifying the root cause, addressing vulnerabilities, clarifying responsibilities, improving training, and strengthening security tools (CISA, 2021). XYZ will conduct thorough post-incident reviews within two weeks of incident resolution to collect and analyze incident data, continuously improving its incident response at both locations and reducing vulnerabilities. Participants in the post-incident review will include the IRT, IT staff, legal personnel, leadership, and other relevant stakeholders. They will review metrics, such as the Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR). This will help address the root cause, clarify employees' responsibilities, enhance training, and reinforce security controls. Additionally, the findings from the post-incident review will be used to update incident response procedures, training material, and security controls, which will ultimately decrease the likelihood and impact of future incidents.

Conclusion

This document establishes the foundation for a comprehensive cybersecurity program at XYZ Insurance and reveals that cybersecurity is not just about technical controls. Protecting the 1,400 users, 1,200 servers, two separate locations, and the business overall requires strong governance, compliance, risk management, security controls, incident response plans, and continued improvement. The NIST CSF 2.0 serves as the foundation of the cybersecurity plan,

ensuring that security efforts align with business goals while addressing the unique challenges at XYZ. Some of these challenges include legacy systems, limited IT staff, regulatory requirements, and locations in separate states. Implementing measures such as MFA, network segmentation, risk and vulnerability management, continuous monitoring, and incident response plans helps reduce the likelihood and impact of cybersecurity incidents. The cybersecurity plan reinforces XYZ's security posture and yields important lessons.

One of the main lessons learned from creating the cybersecurity plan is that it must be an ongoing process, not a one-time, fix-all solution. Given the evolving technology and threat landscape, effective risk management requires continuous threat monitoring, regular evaluation of security controls, and ongoing employee SETA. The plan also includes tools and metrics such as ROSI, risk matrices, cybersecurity profiles, and post-incident reviews, with key metrics such as MTTD and MTTR. These elements drive informed decision-making and continual improvements while guiding future plans.

As XYZ continues to grow, its cybersecurity plan must remain flexible and adaptable to evolving threats, technologies, and regulations. Looking ahead, XYZ should aim to reduce its reliance on legacy systems, enhance its automation and monitoring capabilities, and refine its incident response and recovery plans. Additionally, XYZ should create a culture of cybersecurity supported and promoted by leadership and strengthened by SETA. Meanwhile, staying proactive rather than reactive and focusing on continuous improvements will position XYZ to protect sensitive data, maintain compliance, and support business continuity and goals. Importantly, maintaining a robust cybersecurity plan also builds and sustains customer trust in an increasingly complex digital environment where incidents, as seen in the Equifax breach, can have devastating consequences.

References

- Anchore. (2025, April 22). *Cybersecurity compliance: Laws & regulations to know*.
<https://anchore.com/compliance/>
- Baker Law Group, PLLC. (n.d.). *Common cybersecurity litigation claims in Colorado and how to defend against them*. <https://jbakerlawgroup.com/common-cybersecurity-litigation-claims-in-colorado-and-how-to-defend-against-them/>
- Carpenter, J. (2025, March 6). *ROI vs. ROSI: How to measure cybersecurity investments and risk reduction*. Anchor. <https://anchorcybersecurity.com/blog/crisc-roa-rosi>
- Chin, K. (2025, April 8). *How cybersecurity affects the insurance industry*. UpGuard.
<https://www.upguard.com/blog/how-cybersecurity-affects-the-insurance-industry>
- Cihangir, E. (2025, December 15). *A guide to cybersecurity compliance in the insurance industry*. Specops Software. <https://specopssoft.com/blog/insurance-cybersecurity-compliance-guide/>
- CISA. (2021, November). *Cybersecurity incident & vulnerability response playbooks*. Cybersecurity & Infrastructure Security Agency.
https://www.cisa.gov/sites/default/files/2024-08/Federal_Government_Cybersecurity_Incident_and_Vulnerability_Response_Playbooks_508C.pdf
- Danielson, L. (2025, November 14). *Equifax data breach*. Huntress.
<https://www.huntress.com/threat-library/data-breach/equifax-data-breach>
- Filipek, R. (2023, November 7). *Calculating cybersecurity ROSI*. Corsica Technologies.
<https://corsicatech.com/blog/cybersecurity-roi-rosi-calculator/>

Fortinet. (n.d.). *What is an insider threat?*

<https://www.fortinet.com/resources/cyberglossary/insider-threats>

Khalil, M. (2026, April 23). *Data breach statistics 2025–2026 global trends and insights.*

DeepStrike. <https://deepstrike.io/blog/data-breach-statistics-2025>

Kosinski, M., & Holdsworth, J. (n.d.). *What is incident response?* IBM.

<https://www.ibm.com/think/topics/incident-response>

LaPorte, B. (2025, August 15). *Legacy IT systems: unique protection required.*

Morphisec. <https://www.morphisec.com/blog/legacy-it-systems/>

MetricStream. (n.d.). *Risk matrix: Complete guide with an example.*

<https://www.metricstream.com/learn/what-is-risk-matrix.html>

National Institute of Standards and Technology. (2024, February 26). *The NIST Cybersecurity*

Framework (CSF) 2.0. <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

SafetyCulture. (2026, April 28). *Qualitative & quantitative risk analysis.*

SafetyCulture. <https://safetyculture.com/topics/qualitative-and-quantitative-risk-analysis>

Thomas, C. (n.d.). *Five steps of the risk management process*. 360factors.

<https://www.360factors.com/blog/five-steps-of-risk-management-process/>

Whalley, C., Kenslea, M., Ramachandra, A., & Fletcher, S. (2024, January 25). *Cybersecurity*

incident management and response guide. EDUCAUSE.

<https://er.educause.edu/articles/2024/1/cybersecurity-incident-management-and-response-guide>

Wolverton, M. (n.d.). *Illinois cybersecurity laws you should know (2026)*. PivIT Strategy.

<https://pivitstrategy.com/illinois-cybersecurity-laws-you-should-know-2026/>